

A função de proteger a cibersegurança visa construir sistemas de processamento de TI seguros que apresentem os atributos de confidencialidade, integridade e disponibilidade. Muitos desses sistemas dependem total ou parcialmente da criptografia.

Como profissional de segurança da informação, você deve entender os conceitos por trás dos algoritmos criptográficos e sua implementação em protocolos e serviços seguros. Uma forte compreensão técnica do assunto permitirá que você explique a importância dos sistemas criptográficos e selecione as tecnologias apropriadas para atingir uma meta de segurança.

Nesta lição, você vai fazer o seguinte:

- Comparar e contrastar algoritmos criptográficos.
- Explicar a importância da infraestrutura de chave pública e dos certificados digitais.
- Explicar a importância de usar soluções criptográficas apropriadas para criptografia e troca de chaves.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Criptografia]], que literalmente significa "escrita secreta", é a arte de tornar a informação segura por meio da sua codificação. É o oposto de segurança por meio da ocultação, ou obscuridade, que envolve manter algo em segredo, escondendo-o. Isso é considerado impossível (ou pelo menos de alto risco) em um sistema de computador. Com a criptografia, não importa se terceiros sabem da existência e localização do segredo, porque nunca conseguirão entender as informações sem os meios para decodificá-las.

A seguinte terminologia é usada para discutir criptografia:

- [[Texto simples]] (ou *texto claro*): é uma mensagem não criptografada.
- [[Texto cifrado]]: é uma mensagem criptografada.
- [[Algoritmo]]: é o processo utilizado para criptografar e descriptografar uma mensagem.
- [[Criptanálise]]: é a arte de quebrar sistemas criptográficos.

Ao discutir criptografia e ataques contra sistemas de criptografia, é costume usar um elenco de personagens para descrever os diferentes agentes envolvidos no processo de um ataque. Os principais personagens são:

- **Alice**: a emissora de uma mensagem genuína.
- **Roberto**: o destinatário pretendido da mensagem.
- **Mallory**: uma invasora mal-intencionada que tenta subverter a mensagem de alguma forma.

Existem três principais tipos de algoritmos criptográficos, cada um desempenhando um papel diferente na garantia das propriedades de segurança: confidencialidade, integridade e não repúdio. Esses tipos são algoritmos de hash e dois tipos de cifras de criptografia: simétricas e assimétricas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[algoritmo de criptografia]], ou cifra, é um tipo de processo criptográfico que codifica os dados para que possam ser armazenados ou transmitidos de forma segura, sendo posteriormente descriptografados apenas pelo proprietário ou pelo destinatário pretendido. O uso de uma [[chave]] com a cifra de criptografia garante que a descriptografia só possa ser realizada por uma pessoa autorizada.

Algoritmos de substituição e transposição

Para entender como um algoritmo funciona, é útil considerar algoritmos simples de substituição e transposição. Uma cifra de substituição envolve a substituição de caracteres ou blocos no texto simples por um texto cifrado diferente. Cifras de substituição simples alternam ou embaralham letras do alfabeto. Por exemplo, ROT13 alterna cada letra em 13 posições, então A se torna N, por exemplo. O texto cifrado “Uryyb Jbeyq” pode ser descriptografado como o texto simples “Hello World”.

Diferentemente das cifras de substituição, as unidades em uma cifra de transposição seguem as mesmas em texto simples e cifrado, mas sua ordem é alterada, de acordo com algum mecanismo. Observe como o texto cifrado “HLOOLELWRD” foi produzido:

H L O O L E L W R D

As letras são escritas como colunas e, em seguida, as linhas são concatenadas para criar o texto cifrado.

Os algoritmos modernos de criptografia usam essas técnicas básicas de substituição e transposição de maneiras complexas que conseguem derrotar as tentativas de criptoanálise.

Algoritmos simétricos

Um algoritmo simétrico é aquele no qual a criptografia e a descryptografia são executadas pela mesma chave secreta. A chave secreta deve ser conhecida apenas por pessoas autorizadas. Se ela for perdida ou roubada, a segurança estará comprometida. A [[criptografia simétrica]] é utilizada para garantir a confidencialidade. Por exemplo, Alice e Roberto podem compartilhar um arquivo confidencial da seguinte maneira:

1. Alice e Roberto se reúnem para combinar uma cifra e um valor de chave secreta. Ambos registram o valor da chave secreta, certificando-se de que ninguém mais possa descobri-lo.
2. Alice criptografa um arquivo usando a cifra e a chave.
3. Alice envia apenas o texto cifrado para Roberto pela rede.
4. Roberto recebe o texto cifrado e consegue descryptografá-lo aplicando a mesma cifra usando a sua cópia da chave secreta.

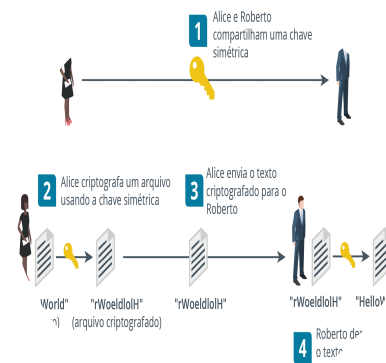


Figura 1. Operação de criptografia simétrica e fraquezas

Imagens © 123RF.com.

Descrição

As etapas envolvidas são as seguintes: 1. Alice e Roberto compartilham uma chave simétrica. 2. Alice criptografa um arquivo usando a chave simétrica, convertendo "HelloWorld" (arquivo) em "rWoeldlolH" (arquivo criptografado). 3. Alice envia o texto cifrado "rWoeldlolH" para Roberto. 4. Roberto descryptografa o texto cifrado usando a mesma chave simétrica, transformando "rWoeldlolH" em "HelloWorld".

A criptografia simétrica é muito rápida. Ela é usada para criptografia em massa de grandes quantidades de dados. O principal problema é como Alice e Roberto "se encontram" para combinar ou trocar a chave. Se Marta interceptar a chave e obtiver o texto cifrado, a segurança estará comprometida.

Nota:

Observe que a criptografia simétrica não pode ser usada para autenticação ou integridade. Alice e Roberto conseguem criar exatamente os mesmos segredos porque ambos conhecem a mesma chave.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os algoritmos de criptografia usam uma chave para aumentar a segurança do processo. Por exemplo, se você considerar a cifra de substituição ROT13, perceberá que a chave é 13. Você pode usar 17 para obter um texto cifrado diferente seguindo o mesmo método. A chave é importante porque, mesmo que o método da cifra seja conhecido, uma mensagem ainda não poderá ser descriptografada sem o conhecimento da chave específica.

O keyspace (espaço da chave) é o intervalo de valores da chave. No exemplo ROT13, o keyspace é 25 (ROT1... ROT25). O uso de ROT0 ou ROT26 resultaria em um texto cifrado idêntico ao texto simples. Usar um valor maior que 26 para percorrer o alfabeto várias vezes é equivalente a uma chave do intervalo 1–25. ROT0 e ROT26+ são chaves fracas e não devem ser usados.

As cifras modernas usam keyspaces grandes, com trilhões de valores de chave possíveis. Isso dificulta a descoberta da chave por meio da criptoanálise de força bruta. *Criptoanálise de força bruta* significa tentar descriptografar o texto cifrado utilizando todos os valores de chave possíveis e ler o resultado para determinar se ainda não faz sentido ou se é texto simples.

As chaves das cifras simétricas modernas usam um número de bits gerado de maneira pseudoaleatória. O número de bits corresponde ao [[tamanho da chave]]. Por exemplo, a cifra simétrica mais comumente usada é o Advanced Encryption Standard (AES). Ele pode ser usado com dois tamanhos de chave. O AES-128 usa uma chave de 128 bits. Um bit pode ter um de dois valores (0 ou 1), então o número de valores de chave possíveis é igual a dois multiplicado por si mesmo um número de vezes equivalente ao tamanho da chave. Ou seja, 2^{128} , onde 2 é a base e 128, o expoente. O AES-256 tem um keyspace de 2^{256} . Esse keyspace não é simplesmente duas vezes maior que o AES-128; é muitos trilhões de vezes maior e, conseqüentemente, significativamente mais resistente a ataques de força bruta.

A desvantagem das chaves maiores é que o computador deve usar mais ciclos de memória e processadores para executar a criptografia e descriptografia.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Em uma cifra de criptografia simétrica, a mesma chave secreta é usada para executar operações de criptografia e descryptografia. Com um [[algoritmo assimétrico]], a criptografia e a descryptografia são realizadas por duas chaves diferentes, porém relacionadas, de um par de [[chaves privada]] e [[pública]].

Quando uma chave pública é usada para criptografar uma mensagem, apenas a chave privada emparelhada pode descryptografar o texto cifrado. A chave pública não pode ser usada para descryptografar o texto criptografado. As chaves são geradas de modo que não seja possível derivar a chave privada a partir da chave pública. Em outras palavras, o proprietário do par de chaves pode distribuir a chave pública para qualquer pessoa de quem deseja receber mensagens seguras:

1. Roberto gera um par de chaves e mantém a chave privada em segredo.
2. Roberto divulga a chave pública.

Alice quer enviar uma mensagem confidencial ao Roberto para pegar uma cópia da chave pública do Roberto.

3. Alice usa a chave pública do Roberto para criptografar a mensagem.
4. Alice envia o texto cifrado para o Roberto.
5. Roberto recebe a mensagem e consegue descryptografá-la usando a sua chave privada.
6. Se Marta estiver bisbilhotando, poderá interceptar a mensagem e a chave pública.
7. No entanto, Marta não pode usar a chave pública para descryptografar a mensagem, portanto, o sistema permanece seguro.



Figura 1. Criptografia assimétrica

(Imagens © 123RF.com.)

Descrição

As etapas envolvidas são as seguintes: 1. Bob gera um par de chaves assimétricas e mantém a chave privada em segredo. 2. Bob publica a chave pública e Alice guarda uma cópia dela. 3. Alice criptografa uma mensagem usando a chave pública de Bob, transformando "HelloWorld" (arquivo) em "rWoeldlolH" (arquivo criptografado). 4. Alice envia o texto cifrado "rWoeldlolH" para Bob. 5. Bob descriptografa o texto cifrado usando a chave privada, revertendo "rWoeldlolH" para "HelloWorld". 6. Mallory fareja o tráfego de rede e descobre o valor da chave pública e o texto cifrado. 7. Mallory não pode usar a chave pública de Bob para reverter a criptografia.

As etapas envolvidas são as seguintes: 1. Bob gera um par de chaves assimétricas e mantém a chave privada em segredo. 2. Bob publica a chave pública e Alice guarda uma cópia dela. 3. Alice criptografa uma mensagem usando a chave pública de Bob, convertendo "HelloWorld" (arquivo) em "rWoeldlolH" (arquivo criptografado). 4. Alice envia o texto cifrado "rWoeldlolH" para Bob. 5. Bob descriptografa o texto cifrado usando a chave privada, transformando "rWoeldlolH" em "HelloWorld". 6. Mallory fareja o tráfego de rede e obtém o valor da chave pública e do texto cifrado. 7. Mallory não pode usar a chave pública de Bob para reverter a criptografia.

A desvantagem da criptografia assimétrica é que ela envolve uma sobrecarga de computação substancial em comparação com a criptografia simétrica. Quando uma grande quantidade de dados está sendo criptografada em disco ou transportada por uma rede, a criptografia assimétrica é ineficiente. Em vez de ser usada para criptografar os dados em massa diretamente, a cifra de chave pública pode ser usada para criptografar uma chave simétrica secreta. Isso permite que Alice e Roberto troquem uma chave de sessão de criptografia em massa sem que Marta possa descobri-la.

Nota:

A criptografia assimétrica pode ser implementada utilizando diversos algoritmos. Cada algoritmo tem um tamanho de chave recomendado diferente. A cifra assimétrica Rivest, Shamir, Adleman (RSA) requer uma chave privada de 2.048 bits para atingir um nível aceitável de segurança. A cifra assimétrica de Elliptic Curve Cryptography (ECC) pode usar chaves privadas de 256 bits para atingir um nível de segurança equivalente a uma chave RSA de 3.072 bits.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um algoritmo de hash criptográfico gera uma sequência de bits de comprimento fixo a partir de um texto simples de entrada que pode ter qualquer tamanho. A saída pode ser chamada de hash ou de resumo da mensagem. A função é projetada para que seja impossível recuperar os dados de texto simples do resumo (unidirecional) e para que diferentes entradas dificilmente produzam a mesma saída (uma colisão).

Um algoritmo de hash é usado para provar a integridade. Por exemplo, Roberto e Alice podem comparar os valores usados para uma senha da seguinte maneira:

1. Roberto tem um resumo calculado a partir da senha de texto simples de Alice. Roberto não consegue recuperar o valor da senha em texto simples a partir do hash.
2. Quando Alice precisa autenticar Roberto, ela digita sua senha, a converte em um hash e envia o resumo para Roberto.
3. Roberto compara o resumo de Alice ao valor do hash no arquivo. Se corresponderem, Roberto terá certeza de que Alice digitou a mesma senha.

Além de comparar os valores da senha, um hash de um arquivo pode ser usado para verificar a integridade desse arquivo após a transferência.

1. Alice executa uma função hash no arquivo setup.exe do produto. Ela publica o resumo em seu site com um link para download do arquivo.
2. Roberto baixa o arquivo setup.exe e faz uma cópia do resumo.
3. Roberto executa a mesma função hash no arquivo setup.exe baixado e o compara ao valor de referência publicado por Alice. Se for igual ao valor publicado no site, Roberto presume que o arquivo tem integridade.
4. Imagine que Marta, porém, pode conseguir substituir o arquivo do link por um arquivo mal-intencionado. No entanto, Marta não tem como alterar o hash de referência.
5. Desta vez, Roberto calcula um hash, mas ele não é igual, levando-o a suspeitar que o arquivo foi adulterado.

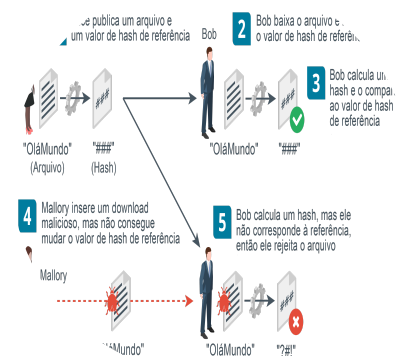


Figura 1. Confirmação do download de um arquivo usando hashes criptográficos

Imagens © 123RF.com.

Descrição

As etapas envolvidas são as seguintes: 1. Alice publica um arquivo (“HelloWorld”) e o valor hash de referência. 2. Bob faz o download do arquivo (“HelloWorld”) e registra o valor hash de referência. 3. Bob calcula um hash e o compara com o valor de referência. 4. Mallory injeta um download malicioso, mas não pode alterar o valor hash de referência. 5. Bob calcula um hash, percebe que não corresponde ao valor de referência e, por isso, rejeita o arquivo.

Existem duas implementações populares dos algoritmos de hash:

- [[Secure Hash Algorithm (SHA)]]: considerado o algoritmo mais robusto. Existem variantes que produzem saídas de tamanhos diferentes, com resumos mais longos e considerados mais seguros. A variante mais popular é a SHA256, que produz um resumo de 256 bits.
- [[Message Digest Algorithm 5 (MD5)]]: gera um resumo de 128 bits. O MD5 não é considerado tão seguro para uso quanto o SHA256, mas pode ser necessário para a compatibilidade entre os produtos de segurança.

Figura 2. Calculando um valor SHA a partir de um arquivo



Captura de tela usada com permissão da Microsoft.

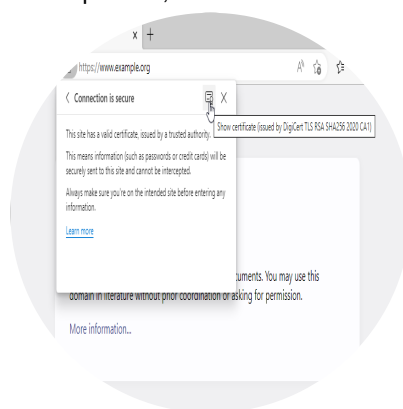


This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma única função hash, cifra simétrica ou cifra assimétrica é chamada de [[primitiva criptográfica]]. É provável que um sistema ou produto criptográfico completo use várias primitivas criptográficas dentro de um conjunto de cifras. As propriedades de diferentes tipos simétricos/assimétricos/hash e de cifras específicas para cada tipo impõem limitações ao seu uso em diferentes contextos e para diferentes finalidades.

A criptografia pode ser usada para garantir a confidencialidade. As cifras criptográficas também podem ser usadas para fins de integridade e autenticação. Se você puder codificar uma mensagem de uma maneira que ninguém mais consiga replicar, o destinatário da mensagem saberá com quem está se comunicando (ou seja, o remetente será autenticado).

Figura 1. A criptografia permite que as entidades se identifiquem e se autenticuem. A entidade pode ser uma pessoa ou um computador, como um servidor web.



Descrição

A mensagem possui o cabeçalho: conexão está segura. Em seguida, o mouse está sobre uma opção com o texto: mostrar certificado (emitido por DigiCert TLS RSA SHA 256 2020 CA1). A mensagem informa: Este site possui um certificado válido, emitido por uma autoridade confiável. Isso significa que as informações (como senhas ou cartões de crédito) serão enviadas de forma segura para este site e não poderão ser interceptadas. Sempre verifique se você está no site correto antes de inserir qualquer informação. Um link abaixo diz: saiba mais.

A criptografia de chave pública consegue autenticar um remetente, pois controla uma chave privada que produz mensagens de maneira única. O hash comprova a integridade calculando um resumo exclusivo de mensagens de tamanho fixo a partir de qualquer entrada de tamanho variável. Essas duas cifras criptográficas podem ser combinadas para criar uma [[assinatura digital]]:

1. O remetente (Alice) cria um resumo de uma mensagem usando um algoritmo de hash pré-acordado, como SHA256, e executa uma operação de assinatura no resumo usando a cifra assimétrica e a chave privada escolhidas.
2. Alice anexa a assinatura digital à mensagem e envia a assinatura e a mensagem para Roberto.
3. Roberto verifica a assinatura usando a chave pública da Alice, obtendo o hash original.
4. Roberto então calcula seu próprio resumo para o documento (usando o mesmo algoritmo que Alice) e o compara com o hash da Alice.

Se os dois resumos forem iguais, os dados não foram adulterados durante a transmissão, e a identidade da Alice está garantida. Se os dados tivessem sido alterados ou se um usuário mal-intencionado (Marta) tivesse interceptado a mensagem e usado uma chave privada diferente para assiná-la, os hashes não seriam iguais.



Figura 2. Autenticação de mensagem e integridade utilizando assinaturas digitais

(Imagens © 123RF.com.)

Descrição

As etapas envolvidas são as seguintes: 1. O resumo da mensagem é assinado com a chave privada de Alice. "HelloWorld" (mensagem), "três hashes" (hash), assinatura digital de Alice. 2. A mensagem com a assinatura digital é enviada para Bob. 3. Bob verifica a assinatura digital utilizando a chave pública de Alice, resultando no resumo da mensagem. 4. Bob gera o resumo da mensagem e compara os dois. "HelloWorld" e "três hashes".

Nota:

Existem vários padrões para criar assinaturas digitais. O Public Key Cryptography Standard #1 (PKCS #1) (Padrão de Criptografia de chave Pública n.º 1) define o uso do algoritmo RSA. O Digital Signature Algorithm (DSA) (Algoritmo de Assinatura Digital) usa uma cifra chamada ElGamal, mas o Elliptic Curve DSA (DSA de Curva Elíptica), ou ECDSA, agora é mais amplamente usado. O DSA e o ECDSA foram desenvolvidos como parte dos Padrões Federais de Processamento de Informações (FIPS) do governo dos EUA.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma Public Key Infrastructure (PKI) (infraestrutura de chave pública) é a estrutura que ajuda a estabelecer a confiança no uso da criptografia de chave pública para assinar e criptografar mensagens por meio de certificados digitais. Um certificado digital é uma afirmação pública de identidade, validada por uma autoridade de certificação (CA).

Como profissional de segurança, é muito provável que você precise instalar e manter serviços de certificado PKI para redes privadas. Talvez seja necessário obter e gerenciar certificados de provedores de PKI terceirizados. Este tópico ajudará você a explicar a importância de usar soluções criptográficas apropriadas para implementar a PKI.

Objetivos abordados no exame:

- 1.4 Explicar a importância de usar soluções criptográficas apropriadas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A criptografia de chave pública resolve o problema de distribuir chaves de criptografia quando você deseja se comunicar de forma segura com outras pessoas ou autenticar uma mensagem enviada para outras pessoas.

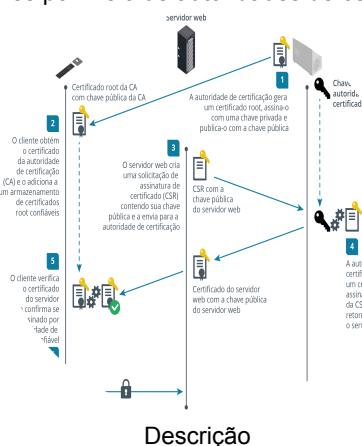
- Quando você quiser que outras pessoas enviem mensagens confidenciais a você, informe a sua chave pública a elas para que a mensagem seja criptografada. A mensagem só poderá ser descriptografada por meio da sua chave privada, que apenas você conhece.
- Quando quiser se autenticar para outras pessoas, você assinará um hash de sua mensagem com sua chave privada. Você informa a elas sua chave pública para que elas verifiquem a assinatura. Como só você sabe a chave privada, é possível ter certeza de que apenas você poderia ter criado a assinatura.

O problema básico da criptografia de chave pública é que, embora o proprietário de uma chave privada possa autenticar mensagens, não há nenhum mecanismo para estabelecer a identidade do proprietário. Esse problema é particularmente evidente com o comércio eletrônico. Como você pode ter certeza de que um site de compras ou serviço bancário é realmente mantido por quem parece ser? O fato de o site estar distribuindo uma chave pública para proteger as comunicações não é garantia da identidade real. Como você sabe que está se correspondendo diretamente com o site usando sua chave pública genuína? Como você pode ter certeza de que não há um autor de ameaças com acesso à rede interceptando e modificando o que você acha que o servidor legítimo está enviando para você?

A [[infraestrutura de chave pública (PKI)]] visa provar que os proprietários de chaves públicas são quem dizem ser. De acordo com a PKI, toda pessoa que emite uma chave pública deve publicá-la em um certificado digital. A validade do certificado é garantida por uma [[autoridade certificadora (CA)]].

A infraestrutura de chave pública (PKI) pode utilizar [[autoridades certificadoras de terceiros]] ou privadas. Uma CA privada pode ser configurada dentro de uma organização para comunicações internas. Os certificados que ela emite só serão confiáveis na organização. Para comunicações públicas ou entre empresas, uma CA de terceiros pode ser usada para estabelecer uma relação de confiança entre servidores e clientes. Exemplos de CAs de terceiros incluem Comodo, DigiCert, GeoTrust, IdenTrust e Let's Encrypt.

Figura 1. A infraestrutura de chave pública permite que os clientes estabeleçam um relacionamento de confiança com os servidores por meio de autoridades de certificação.



As etapas são as seguintes: 1.A CA gera um certificado raiz, assina-o com a chave privada e o publica junto com a chave pública. 2.O cliente obtém o certificado da CA e o adiciona ao repositório de certificados raiz confiáveis. 3.O servidor web cria uma solicitação de assinatura de certificado (CSR) contendo sua chave pública e a envia para a CA. 4.A CA gera um certificado assinado a partir do CSR e o retorna ao servidor web. 5.O cliente verifica o certificado do servidor web e valida se ele foi assinado por uma CA confiável. 6.Cliente e servidor estabelecem uma conexão segura e criptografada.

As funções de uma CA pública de terceiros são:

- Fornecer diversos serviços de certificação úteis para a comunidade de usuários atendidos pela CA.
- Garantir a validade dos certificados e a identidade daqueles que os solicitam (registro).
- Estabelecer confiança na CA com usuários, governos, autoridades reguladoras e empresas (p. ex., instituições financeiras).
- Gerenciar os servidores (repositórios) que armazenam e administram os certificados.

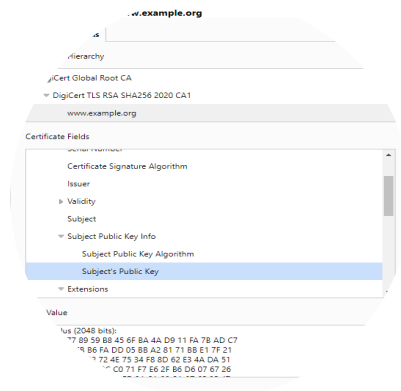
- Realizar o gerenciamento do ciclo de vida de chaves e certificados, principalmente revogando certificados inválidos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um [[certificado digital]] é, essencialmente, uma estrutura que envolve a chave pública de um titular. Além da chave pública, contém informações sobre a entidade e o próprio emissor. O certificado é assinado digitalmente para provar que foi emitido para a entidade por um CA específico. A entidade pode ser um usuário humano (para certificados que permitem a assinatura de mensagens, por exemplo) ou um servidor de computador (para um servidor web que hospeda transações confidenciais, por exemplo).

Figura 1. Detalhes do certificado digital mostrando a chave pública da entidade.



Captura de tela usada com permissão da Microsoft.

Descrição

A janela possui duas abas no topo: Geral e Detalhes (selecionada). As três caixas abaixo são chamadas de hierarquia de certificados, campos do certificado e valor do campo. www.example.org (<http://www.example.org>) está selecionado na caixa chamada hierarquia de certificados e “chave pública do titular” está selecionado na caixa chamada campos do certificado. A caixa intitulada valor do campo exibe os valores sob o título módulo (2048 bits).

Nota:

Certificados digitais são baseados no padrão X.509, aprovado pela União Internacional de Telecomunicações e padronizado pela Internet Engineering Task Force (tools.ietf.org/html/rfc5280) ([http://tools.ietf.org/html/rfc5280](https://tools.ietf.org/html/rfc5280)). A RSA também criou um conjunto de normas, denominadas [[Public Key Cryptography Standards (PKCS)]], para promover o

uso da infraestrutura de chave pública.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O *modelo de raiz de confiança* define como os usuários e diferentes CAs podem confiar uns nos outros. Cada CA emite um certificado para si mesma. Isso é denominado [[certificado raiz]]. O certificado root é autoassinado, isto é, o servidor da CA assina um certificado emitido para si mesma. Um certificado root usa uma chave RSA de 2.048 ou 4.096 bits ou o equivalente em ECC. O sujeito (entidade) do certificado root é definido como o nome da organização/CA, por exemplo, “CompTIA Root CA”.

O certificado root pode ser usado para assinar outros certificados emitidos pela CA. Instalar o certificado root da CA significa que os hosts confiarão automaticamente em todos os certificados assinados por essa CA.

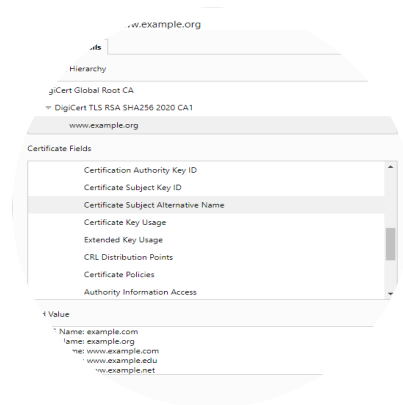
CA única

Neste modelo simples, uma única CA root emite certificados diretamente para usuários e computadores. Este modelo de CA única é frequentemente usado em redes privadas. O problema dessa abordagem é que o servidor de uma única CA está muito exposto. Se estiver comprometido, toda a PKI entra em colapso.

CAs de terceiros

A maioria das CAs de terceiros opera seguindo um modelo hierárquico. No modelo hierárquico, a CA root emite certificados para uma ou mais CAs intermediárias. As CAs intermediárias emitem certificados para entidades (entidades de folha ou finais). Este modelo tem a vantagem de que diferentes CAs intermediárias podem ser configuradas com políticas de certificado, permitindo que os usuários percebam claramente para que um determinado certificado foi projetado. Cada certificado de folha pode ser rastreado até a CA root ao longo do caminho da certificação. Isso também é chamado de [[encadeamento]] de *certificados ou cadeia de confiança*.

Figura 1. O servidor web de www.example.org (<http://www.example.org>) é identificado por um certificado emitido pela CA intermediária DigiCert TLS CA1. O certificado da CA intermediária é assinado pela Global Root CA da DigiCert.



Captura de tela usada com permissão da Microsoft.

Descrição

A janela possui duas abas no topo: Geral e Detalhes (selecionada). As três caixas abaixo são intituladas hierarquia de certificados, campos do certificado e valor do campo. www.example.org (<http://www.example.org>), está selecionado na caixa chamada hierarquia de certificados e “nome alternativo do certificado do titular” está selecionado na caixa chamada campos do certificado. A caixa intitulada valor do campo lista os diversos nomes DNS. Um botão exportar está no canto inferior direito.

Certificados autoassinados

Em algumas circunstâncias, o uso da PKI pode ser muito difícil ou caro de gerenciar. Qualquer máquina, servidor web ou código de programa pode ser implementado com um [[certificado autoassinado]]. Por exemplo, as interfaces administrativas web dos roteadores do consumidor geralmente são protegidas apenas por um certificado autoassinado.

Os certificados autoassinados também podem ser úteis em ambientes de desenvolvimento e teste. O sistema operacional ou navegador marca os certificados autoassinados como não confiáveis, mas um usuário pode optar por ignorar isso. A natureza dos certificados autoassinados os torna muito difíceis de validar. Eles não devem ser usados para proteger hosts e aplicativos críticos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O registro é o processo pelo qual os usuários finais criam uma conta com a CA e ficam autorizados a solicitar certificados. Os processos exatos pelos quais os usuários são autorizados e sua identidade comprovada são determinados pela implementação da CA. Por exemplo, em uma rede de domínio do Windows, os usuários e dispositivos geralmente podem se inscrever automaticamente na CA apenas fazendo a autenticação no Active Directory. Uma CA de terceiros pode realizar uma série de testes para garantir a identidade de uma entidade. É do interesse da CA garantir que ela emita apenas certificados para usuários legítimos, ou sua reputação será prejudicada.

Quando uma entidade deseja obter um certificado, ela primeiro gera um par de chaves, uma assimétrica privada e uma pública, para a cifra escolhida, como RSA ou ECC, e o tamanho da chave. A chave privada deve ser mantida bem protegida e ser conhecida apenas pela entidade. Em seguida, o solicitante preenche uma solicitação de [[assinatura de certificado (CSR)]] e a envia para a CA. A CSR é um arquivo que contém as informações que a entidade deseja usar no certificado, incluindo sua chave pública.

A autoridade de certificação analisa o certificado e verifica se as informações são válidas. Para um servidor Web, isso pode significar simplesmente verificar se o nome da entidade e o Fully Qualified Domain Name (FQDN) (nome de domínio totalmente qualificado) são idênticos e verificar se a CSR foi iniciada pela pessoa administrativamente responsável pelo domínio, conforme identificado nos registros WHOIS deste. Se a solicitação for aceita, a autoridade de certificação assinará o certificado e o enviará à entidade.

Figura 1. Usar um formulário Web no dispositivo de firewall OPNsense para solicitar um certificado. Os nomes alternativos de DNS e IP devem corresponder aos valores que os clientes usarão para navegar no site.

OPNsense

Create a Certificate Signing Request

Descriptive name: gw.ad.structureality.com

External Signing Request

Key Type: RSA

Key length (bits): 2048

Digest Algorithm: SHA256

Distinguished name

Common Name: gw.ad.structureality.com

Alternative Names

Type	Value
DNS	gw.ad.structureality.com
IP	10.1.128.253

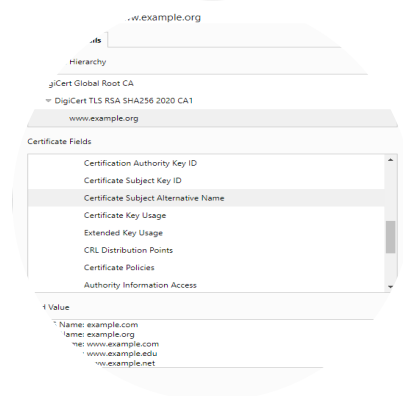
Diagram: A server icon is connected to three mobile device icons, representing a network configuration.

This content is only available on larger screen sizes. Please revisit this page on a larger device.

Quando os certificados foram introduzidos, o atributo [[common name (CN)]] era utilizado para identificar o nome de domínio totalmente qualificado (FQDN) pelo qual o servidor é acessado, como por exemplo `www.comptia.org`. No entanto, esse uso cresceu de forma orgânica e não por design. O atributo de CN pode conter diferentes tipos de informações, tornando difícil para um navegador interpretá-las corretamente. Consequentemente, não é mais utilizado como método de validação de identidade de uma entidade que precisa ser resolvida em algum tipo de endereço de rede.

O campo de extensão [[subject alternative name (SAN)]] é estruturado para representar diferentes tipos de identificadores, incluindo FQDNs e endereços IP. Se um certificado for configurado com um SAN, o navegador deve validar isso e ignorar o valor de CN.

Figura 1. O certificado do domínio de exemplo é configurado com nomes de entidade alternativos para diferentes domínios de nível superior e subdomínios.



Captura de tela usada com permissão da Microsoft.

Descrição

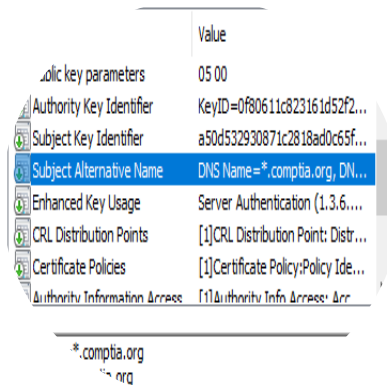
A janela possui duas abas no topo: Geral e Detalhes (selecionada). As três caixas abaixo são intituladas hierarquia de certificados, campos do certificado e valor do campo. Está selecionado na caixa chamada hierarquia de certificados e “nome alternativo do certificado do titular” está selecionado na caixa chamada campos do certificado. A caixa intitulada valor do campo lista os diversos nomes DNS. Um botão exportar está no canto inferior direito.

Nota:

Ainda é mais seguro colocar o FQDN no CN também, porque nem todos os navegadores e implementações se mantêm atualizados com os padrões mais recentes.

O campo SAN também permite que um certificado represente diferentes subdomínios, como `www.comptia.org` e `members.comptia.org`. Listar os subdomínios específicos é mais seguro, mas se um novo subdomínio for adicionado, um novo certificado deve ser emitido. Um [[domínio curinga]], como `*.comptia.org`, significa que o certificado emitido para o domínio principal será aceito como válido para todos os subdomínios (em um único nível).

Figura 2. O certificado do site da CompTIA é configurado com um domínio curinga, permitindo o acesso via <https://comptia.org> (<https://comptia.org>) ou <https://www.comptia.org> (<https://www.comptia.org>).



(Captura de tela usada com permissão da Microsoft.)

Descrição

Vários campos estão listados à esquerda e os valores à direita. O campo “Subject Alternative Name” e o valor “DNS Name igual a asterisco ponto comptia ponto org ponto DN” estão selecionados.

Nota:

Um certificado também contém campos para Organização (O), Unidade Organizacional (OU), Localidade (L), Estado (ST) e País (C). Eles são concatenados com o nome comum para formar um Distinguished Name (DN) (nome distinto).

Por exemplo, o DN da Example LLC poderia ser o seguinte: CN=www.example.com, OU=Web Hosting, O=Example LLC, L=Chicago, ST=Illinois, C=US.

Nota:

Diferentes tipos de certificados podem ser usados para fins distintos da identificação do servidor/computador. As contas de usuário podem ser emitidas com certificados de e-mail; nesse caso, o SAN é um endereço de email RFC 822. Um certificado de assinatura de código é usado para verificar o editor ou desenvolvedor de software e scripts. Esses não utilizam um SAN, mas a CA deve validar a organização e os dados de localização para garantir a precisão e evitar que um desenvolvedor mal-intencionado tente se passar por uma empresa de software conhecida.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

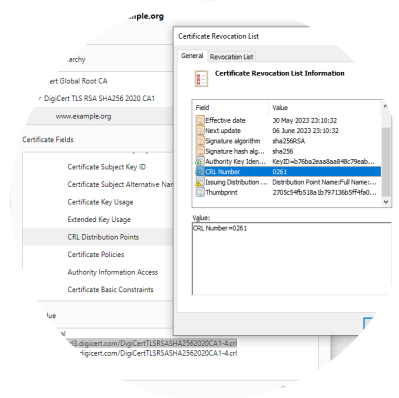
Um certificado pode ser revogado ou suspenso:

- Um certificado revogado não é mais válido e não pode ser “des-revogado” ou reintegrado.
- Um certificado suspenso pode ser reativado.

Um certificado pode ser revogado ou suspenso pelo proprietário ou pela CA por vários motivos. Por exemplo, a chave privada pode ter sido comprometida, a empresa pode ter fechado, um usuário pode ter saído da empresa, um nome de domínio pode ter sido alterado, o certificado pode ter sido usado indevidamente e assim por diante. Esses motivos são codificados em opções como Unspecified (não especificado), Key Compromise (chave comprometida), CA Compromise (CA comprometida), Superseded (substituído) ou Cessation of Operation (operação encerrada). Uma chave suspensa recebe o código Certificate Hold (suspensão de certificado).

Deve haver um mecanismo para informar aos usuários se um certificado é válido, revogado ou suspenso. Uma CA deve manter uma lista de [[revogação de certificados (CRL)]] com todos os certificados revogados e suspensos. A CRL deve estar acessível a qualquer pessoa que precisar confiar na validade dos certificados da CA. Cada certificado deve conter informações para o navegador sobre como verificar a CRL.

Figura 1. O campo de ponto de distribuição em um certificado digital identifica o local da lista de certificados revogados, que são publicados em um arquivo de CRL assinado pela CA.



Captura de tela usada com permissão da Microsoft.

Descrição

A janela do visualizador de certificados possui duas abas no topo: Geral e Detalhes (selecionada). As três caixas abaixo são intituladas hierarquia de certificados, campos do certificado e valor do campo. www.example.org (<http://www.example.org>) está selecionado na caixa chamada hierarquia de certificados e CRL distribution points está selecionado na caixa chamada campos do certificado. A caixa intitulada valor do campo lista dois URLs sob o título não crítico. O primeiro está selecionado. Um botão exportar está no canto inferior direito. A janela da lista de revogação de certificados possui duas abas: geral (selecionada) e lista de revogação. Uma tabela sob o título informações da lista de revogação de certificados lista o campo e os valores. O campo “CRL number” e o valor “0261” estão selecionados. Uma caixa intitulada valor exibe CRL Number igual a 0261. Um botão OK no canto inferior direito está selecionado.

Uma CRL tem os seguintes atributos:

- **Período de publicação:** a data e hora em que a CRL é publicada. A maioria das CAs é configurada para publicar a CRL automaticamente.

- **Ponto(s) de distribuição:** o(s) local(is) onde a CRL é publicada.
- **Período de validade:** o período durante o qual a CRL é considerada autorizada. Esse é geralmente um pouco mais longo do que o período de publicação (por exemplo, se o período de publicação fosse a cada 24 horas, o período de validade poderia ser de 25 horas).
- **Assinatura:** a CRL é assinada pela CA para verificar sua autenticidade.

Com o sistema de CRL, existe o risco de o certificado ser revogado, mas ainda aceito pelos clientes porque uma CRL atualizada não foi publicada. Um outro problema é que o navegador (ou outro aplicativo) pode não estar configurado para realizar a verificação de CRL, embora isso atualmente aconteça apenas com softwares de navegador obsoletos.

Outra forma de fornecer informações atualizadas é verificar o status do certificado em um *servidor* [[Online Certificate Status Protocol (OCSP)]]]. Em vez de retornar uma CRL inteira, isso comunica o status do certificado solicitado. Os detalhes do serviço de resposta do OCSP devem estar publicados no certificado.

A maioria dos servidores de OCSP consegue consultar o banco de dados de certificados diretamente e obter o status de um certificado em tempo real. Outros servidores de OCSP dependem das CRLs em si e são limitados pelo intervalo de publicação de CRLs.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O *gerenciamento de chaves* refere-se às considerações operacionais para as várias etapas do ciclo de vida de uma chave. O ciclo de vida de uma chave pode envolver os seguintes estágios:

- **Geração da chave:** cria um par de chaves assimétricas ou uma chave secreta simétrica da força necessária usando a cifra escolhida.
- **Armazenamento:** impede o acesso não autorizado a uma chave privada ou secreta e protege contra perda ou dano.
- **Revogação:** impede o uso da chave se ela estiver comprometida. Se uma chave for revogada, todos os dados que foram criptografados com ela devem ser recriptografados utilizando uma nova chave.
- **Expiração e renovação:** dá ao certificado um “prazo de validade”, aumentando a segurança. Cada certificado expira após um determinado período. Os certificados podem ser renovados com o mesmo par de chaves ou com um novo par.

Um modelo de gerenciamento de chaves descentralizado significa que as chaves são geradas e gerenciadas diretamente no computador ou na conta do usuário que usará o certificado. Isso não requer nenhuma configuração especial e, portanto, é fácil de implantar. Entretanto, isso dificulta a detecção de chaves comprometidas.

Algumas organizações preferem centralizar a geração e o armazenamento de chaves utilizando uma ferramenta como um [[sistema de gerenciamento de chaves]]. Em um tipo de sistema de gerenciamento de chaves criptográficas, um servidor ou dispositivo dedicado é usado para gerar e armazenar chaves. Quando um dispositivo ou aplicativo precisa executar uma operação criptográfica, ele usa o Key Management Interoperability Protocol (KMIP) (protocolo de interoperabilidade de gerenciamento de chaves) para se comunicar com o servidor.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um par de chaves ou chave secreta pode ser gerado e armazenado no sistema de arquivos de um computador desktop ou servidor executando um sistema operacional de uso geral. No entanto, isso tem uma série de desvantagens:

- **Uma chave criptográfica precisa ser gerada usando um processo aleatório.** Um sistema de geração de chaves com alto grau de aleatoriedade — ou [[entropia]] — garante que qualquer valor do espaço de chaves possível tenha a mesma chance de ser selecionado que qualquer outro. Entretanto, hardware e software de computador possuem entropia extremamente baixa. Os computadores processam instruções de uma maneira totalmente determinística. Um computador pode utilizar um software de [[pseudo-RNG (PRNG)]] que, embora ainda seja determinístico, consegue simular um alto nível de aleatoriedade. Uma segurança superior é obtida com hardware de geração de [[números verdadeiramente aleatórios (TRNG)]]. Isso usa uma fonte de entropia, como ruído ou movimento do ar, como uma semente não determinística para gerar o valor-chave.
- **Uma chave armazenada no sistema de arquivos é tão segura quanto qualquer outro arquivo.** Ela pode ser facilmente comprometida por meio da credencial do usuário ou roubo físico do dispositivo. Também é difícil garantir que o acesso às chaves seja totalmente auditado. O ideal é que o armazenamento criptográfico evidencie claramente qualquer violação. Isso significa que se deve saber imediatamente quando uma chave privada ou secreta for comprometida, assim ela pode ser revogada e qualquer texto criptografado é criptografado novamente com uma nova chave.

Figura 1. Pseudo RNG em operação durante a geração de chaves usando o GPG. Este método ganha entropia com o uso do mouse e do teclado do usuário.



Essas desvantagens podem ser resolvidas usando um criptoprocessador para geração e armazenamento de chaves. Por ser dedicado a uma única função, o hardware do criptoprocessador tem uma superfície de ataque menor do que um computador de uso geral. Um criptoprocessador também consegue realizar operações como descryptografia e assinatura em nome de aplicativos. Isso significa que o material da chave nunca sai do criptoprocessador.

Existem duas maneiras principais de implementar hardware de criptoprocessador: TPMs e HSMs.

Trusted Platform Module (módulo de plataforma confiável)

[[Um Trusted Platform Module (TPM)]] é um dispositivo de criptoprocessamento implementado como um módulo para uma plataforma computacional específica, como um computador desktop, dispositivo móvel ou sistema embarcado. TPMs são produzidos de acordo com as especificações das versões 1.2 e 2.0. A versão 2.0 não é retrocompatível com a versão 1.2. A maioria dos fornecedores descontinua a versão 1.2.

Além das versões suportadas, existem três formas principais de implementação de um TPM:

- Discrete significa que o TPM é implementado como um chip dedicado. Isso proporciona resistência à violação e a menor superfície de ataque.
- Integrated significa que o TPM faz parte de um chipset ou CPU que executa outras funções. Essa implementação não é resistente à violação e possui uma superfície de ataque mais ampla.
- Firmware significa que o TPM é implementado no código operacional de baixo nível da plataforma. Isso depende da função de enclave seguro do CPU ou chipset para proteger o material criptográfico. Exemplos dessas soluções incluem o Platform Trust Technology (PTT) da Intel e o fTPM da AMD. Essa implementação não oferece resistência à violação e apresenta a superfície de ataque mais ampla (incluindo o código que sustenta a funcionalidade de enclave seguro do CPU ou chipset).

Nota:

Um TPM virtual pode ser implementado em um hipervisor para fornecer serviço a máquinas virtuais (VMs).

Hardware Security Module (módulo de segurança de hardware)

Um [[hardware security module (HSM)]] é um dispositivo de criptoprocessamento implementado em um formato removível ou dedicado, incluindo appliances montados em rack, placas adaptadoras PCIe plugáveis e chaves de segurança conectadas via USB. Também é possível provisionar um HSM como um dispositivo virtual. Enquanto um TPM é projetado para validar a segurança de uma plataforma computacional específica, como um computador desktop ou laptop, um HSM oferece armazenamento centralizado de chaves para hosts de rede ou armazenamento portátil de chaves que pode ser utilizado por pessoas em diferentes dispositivos.

Figura 2. Dispositivo de módulo de segurança de hardware em um fator de forma montado em rack.



(Imagens © 123RF.com.)

Nota:

Os fornecedores podem certificar seus produtos de acordo com o padrão Federal Information Processing Standard 140 Level 2 (FIPS 140-2) para estabelecer confiança no mercado.

Enclave seguro

O uso de um criptoprocessador significa que as chaves não são diretamente acessíveis por meio do sistema de arquivos. O criptoprocessador interage com aplicativos que precisam acessar a chave por meio de uma [[interface de programação de aplicativos (API)]] que implementa o padrão PKCS#11.

Uma vulnerabilidade nesse sistema é que os dados descriptografados precisam ser carregados na memória do sistema (RAM) do computador para que os aplicativos os acessem. Isso aumenta a possibilidade de que um processo mal-intencionado obtenha acesso aos dados por meio de algum tipo de exploração. Essa vulnerabilidade pode ser mitigada por meio da implementação de um enclave seguro. Um enclave seguro de Trusted Execution Environment (TEE) (ambiente de execução confiável), como as Intel Software Guard Extensions, consegue proteger os dados armazenados na memória do sistema para que um processo não confiável não possa lê-los. Um [enclave seguro] é projetado para que até mesmo processos com privilégios de root ou sistema não possam acessá-lo sem autorização. O enclave é bloqueado usando uma lista de um ou mais processos assinados digitalmente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Se uma chave privada ou secreta for perdida ou danificada, os textos criptografados não poderão ser recuperados, a menos que um backup da chave tenha sido feito. Fazer cópias da chave é problemático, pois a probabilidade de uma cópia ser comprometida é maior e é mais difícil detectar que ocorreu um comprometimento.

Esses problemas podem ser mitigados usando os controles de escrow e M de N. [[Escrow]] significa que algo é mantido de forma independente. No contexto do gerenciamento de chaves, isso se refere ao arquivamento de uma chave (ou chaves) por um terceiro. M de N significa que uma operação não pode ser realizada por um único indivíduo. Em vez disso, um quórum ou número mínimo (M) dentre as pessoas disponíveis (N) deve concordar em autorizar a operação.

Uma chave pode ser dividida em partes. Cada parte pode ser mantida por provedores de escrow separados, reduzindo o risco de comprometimento. Uma conta com permissão para acessar uma chave mantida em escrow é chamada de Key Recovery Agent (KRA) (agente de recuperação de chave). Uma política de recuperação pode exigir dois ou mais KRAs para autorizar a operação. Isso reduz o risco de um KRA tentar se passar pelo proprietário da chave.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Como profissional de segurança de TI, você deve ser capaz de selecionar soluções criptográficas apropriadas para um determinado problema de segurança. Uma solução criptográfica usa cifras e ferramentas, como certificados digitais e assinaturas, para implementar um controle de segurança. Os controles criptográficos podem ser usados para proteger arquivos de dados e bancos de dados, assim como as informações transferidas pelas redes.

Objetivos abordados no exame:

- 1.4 Explicar a importância de usar soluções criptográficas apropriadas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Se os dados forem criptografados, não importa se o disco que armazena as informações for roubado ou se foram interceptados ao serem transferidos por meio de uma rede, pois o agente da ameaça não conseguirá entender ou alterar o que foi roubado. Este uso de criptografia cumpre o objetivo de confidencialidade.

Ao implantar um sistema criptográfico para proteger os ativos de dados, deve-se considerar todas as maneiras pelas quais as informações podem ser potencialmente interceptadas. Os dados podem ser classificados em três estados distintos:

- [[Dado em repouso]]: é o estado em que o dado está armazenado em algum tipo de mídia de armazenamento persistente.
- [[Dados em trânsito]] (ou [[dados em movimento]]): nesse estado os dados são transmitidos por uma rede.
- [[Dados em uso]] (ou [[dados em processamento]]): nesse estado os dados estão presentes na memória volátil, como registros e cache de RAM ou CPU do sistema.

A criptografia de megabytes ou gigabytes de dados é chamada de criptografia em massa. A criptografia assimétrica e os pares de chaves privadas/públicas não costumam ser usados para criptografia em massa porque um algoritmo assimétrico não consegue processar grandes quantidades de dados de forma eficiente. A sobrecarga computacional é muito alta ao usar esse tipo de algoritmo para criptografar o conteúdo de um disco ou série de pacotes de rede.

Portanto, a criptografia de dados em massa usa uma cifra simétrica, como AES. Uma *cifra simétrica* consegue criptografar e descriptografar arquivos de dados e fluxos de tráfego de rede rapidamente. O problema é que distribuir uma chave simétrica é um desafio. Quanto mais pessoas conhecem o valor principal, mais fraca é a propriedade de confidencialidade. Felizmente, as chaves simétricas têm apenas 128 bits ou 256 bits de comprimento e, portanto, podem ser facilmente criptografadas usando uma chave pública. Consequentemente, a maioria dos sistemas de criptografia de dados usa criptografia simétrica e assimétrica no seguinte tipo de esquema:

1. O usuário gera um par de chaves assimétricas para a cifra escolhida, como RSA ou ECC.

A parte privada da chave é criptografada, o que significa que o usuário precisa fornecer a sua credencial da conta para usá-la. Nesse contexto, a chave privada é a Key Encryption Key (KEK).

2. O sistema gera uma chave simétrica secreta para a cifra escolhida, como AES256 ou AES512.

Isso é chamado de chave de criptografia de arquivo, de mídia ou de dados (Data Encryption Key — DEK). Essa chave é usada para criptografar os dados-alvo.

3. A chave de criptografia de dados é então criptografada usando a parte da chave pública da KEK.
4. Para acessar dados criptografados, o usuário deve fornecer uma senha ou iniciar uma sessão autenticada para usar a sua chave privada para descriptografar a chave secreta, que pode então descriptografar os dados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os dados em repouso abrangem um grande número de mecanismos de armazenamento. Esses podem ser considerados em termos de [[níveis de criptografia]]. Os níveis mais baixos, como a criptografia de um disco inteiro, têm a vantagem da simplicidade, mas podem ser complexos de gerenciar quando vários usuários precisam acessar os dados. Níveis mais altos, como a aplicação de criptografia por meio do sistema de arquivos ou de um sistema de gerenciamento de banco de dados, podem ser combinados a controles de acesso granulares.

Criptografia completa do disco e da partição

Full-disk encryption (FDE) (criptografia completa do disco) refere-se a um produto que criptografa todo o conteúdo de um dispositivo de armazenamento, incluindo áreas de metadados normalmente não acessíveis usando ferramentas comuns do explorador de arquivos do sistema operacional. A FDE também criptografa áreas de espaço livre. A FDE protege principalmente contra o roubo físico do disco. Um disco roubado pode ser instalado em qualquer computador e o invasor pode se apropriar de todos os arquivos de dados. Isso não é possível se o disco for criptografado, porque ele deve ser desbloqueado pela credencial do usuário para acessar a chave de descriptografia.

Muitos dispositivos de armazenamento podem realizar a autcriptografia usando um produto criptográfico integrado ao firmware do disco. Uma Self-Encrypting Drive (SED) (unidade autcriptografada) pode ser uma hard disk drive (HDD) (unidade de disco rígido), uma solid state drive (SSD) (unidade de estado sólido) ou uma unidade flash USB. O firmware do disco implementa um criptoprocessador para armazenar as chaves para que elas não sejam expostas diretamente ao sistema operacional que monta o disco.

Um HDD ou SSD pode ser dividido em áreas lógicas separadas chamadas partições. Cada partição pode ser formatada com um sistema de arquivos diferente e montada como uma unidade ou volume no sistema operacional. Alguns produtos de criptografia de disco podem conseguir criptografar essas partições de forma seletiva, em vez de criptografar o disco todo. As partições podem ser criptografadas usando chaves diferentes. Por exemplo, um disco pode conter

partições de inicialização, sistema e dados. As partições de inicialização e do sistema podem ser deixadas sem criptografia, pois contêm apenas arquivos padrão do sistema operacional, enquanto a partição de dados é protegida por criptografia.

Criptografia de volume e arquivo

Um volume é qualquer recurso de armazenamento com um sistema único de arquivos. Dito de outra forma, um volume é a maneira como o sistema operacional “vê” um recurso de armazenamento. A tecnologia por trás do volume pode ser um disco removível ou uma partição em um HDD ou SSD. Também pode ser uma matriz RAID. Consequentemente, é provável que um produto de criptografia de volume se refira a um produto implementado como um aplicativo de software, e não por firmware de disco. Por exemplo, embora possam ser vagamente chamados de “criptografia de disco”, os produtos BitLocker, da Microsoft, e FileVault, da Apple, realizam criptografia de volume. Um produto de criptografia de volume pode ou não criptografar espaço livre e/ou metadados de arquivos.

Um produto de criptografia de arquivos é um software que aplica a criptografia a arquivos individuais (ou talvez a pastas/diretórios). Isso pode depender do suporte ao sistema de arquivos. Por exemplo, o Encrypting File System (EFS) da Microsoft exige que o volume seja formatado com NTFS.

Nota:

Os metadados podem incluir uma lista de arquivos, o proprietário do arquivo e as datas de criação/última modificação. O espaço livre ou não alocado pode conter vestígios de dados quando um arquivo tiver sido marcado como excluído mas seus dados não tiverem sido realmente apagados da mídia de armazenamento.

Nota:

Se o dispositivo tiver um TPM ou HSM compatível com o produto de criptografia, o sistema de disco/volume/arquivos pode ser bloqueado por chaves armazenadas no TPM ou HSM.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um banco de dados estruturado armazena dados em tabelas. Cada tabela é composta de campos de coluna com um determinado tipo de dado. Os registros são armazenados como linhas na tabela com um valor inserido para cada campo. Os dados da tabela são armazenados como arquivos em um volume, mas o acesso é projetado para ser

mediado por um database management system (DBMS) (sistema de gerenciamento de banco de dados) executando uma linguagem de banco de dados, como a Structured Query Language (SQL). Normalmente, o banco de dados é hospedado em um servidor e acessado por aplicativos clientes.

Os arquivos nele podem ser protegidos por um produto de criptografia de disco ou volume em execução no servidor. Isso normalmente terá um impacto negativo no desempenho, por isso a criptografia é mais comumente implementada por um DBMS ou plug-in. A criptografia pode ser aplicada em diferentes níveis granulares. Embora cada DBMS suporte recursos diferentes, as seguintes opções de criptografia, baseadas no SQL Server DBMS da Microsoft, são típicas.

Criptografia do banco de dados

A criptografia e descriptografia do banco de dados ou da página ocorre quando dados são transferidos entre o disco e a memória. Isso é chamado de transparent data encryption (TDE) (criptografia de dados transparente) no SQL Server. Uma página é o meio pelo qual o mecanismo de banco de dados retorna os dados solicitados por uma consulta dos arquivos de armazenamento subjacentes. Esse tipo de criptografia significa que todos os registros são criptografados enquanto estão armazenados em disco, protegendo contra roubo da mídia subjacente. Ele também criptografa os logs gerados pelo banco de dados.

Criptografia de registro

Muitos bancos de dados contêm segredos que não devem ser conhecidos pelo administrador do banco de dados. A criptografia de chave pública pode resolver esse problema armazenando a chave privada usada para desbloquear o valor de uma célula fora do banco de dados.

A criptografia de célula/coluna é aplicada a um ou mais campos dentro de uma tabela. Isso pode ter menos impacto no desempenho do que a criptografia do banco de dados, mas o administrador precisa identificar quais campos precisam de proteção. Isso também pode complicar o acesso do cliente aos dados. O mecanismo de criptografia/descriptografia pode funcionar de várias maneiras, mas com o recurso Always Encrypted do SQL Server, os dados permanecem criptografados quando carregados na memória. Eles só são descriptografados quando o aplicativo cliente fornece a chave. A chave de texto simples não está disponível para o DBMS, portanto, o administrador do banco de dados não consegue descriptografar os dados. Isso permite a separação de funções entre o administrador do banco de dados e o proprietário dos dados, o que é importante para a privacidade.

Algumas soluções também podem oferecer suporte à criptografia de registros. Por exemplo, o banco de dados de uma seguradora de saúde pode armazenar informações de saúde protegidas sobre seus clientes. Cada cliente pode ser identificado por um par de chaves separado. Esse par de chaves seria usado para criptografar dados das linhas/registros. A tabela contém registros protegidos separadamente por chaves diferentes. Isso permite o controle refinado de como os dados podem ser acessados para atender aos requisitos de conformidade de segurança e privacidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [[criptografia de transporte - comunicação]] protege os dados em trânsito. Vários produtos de criptografia de transporte foram desenvolvidos para diferentes soluções de rede. Alguns exemplos incluem:

- **Wi-Fi Protected Access (WPA):** o acesso Wi-Fi protegido protege o tráfego enviado por uma rede wireless.
- **Internet Protocol Security (IPsec):** o protocolo de segurança IP protege o tráfego enviado entre dois pontos de extremidade por meio de uma rede de transporte pública ou não confiável. Isto é chamado de rede virtual privada (VPN).
- **Transport Layer Security (TLS):** a segurança de camada de transporte protege dados da aplicação, como dados da Web ou de e-mail, enviados por meio de uma rede pública ou não confiável.

Assim como com os dados em repouso, uma cifra assimétrica normalmente não é usada para criptografar diretamente os dados de rede por ser muito ineficiente. Produtos de criptografia de transporte utilizam um sistema de [[troca de chaves]]. Isso permite que o remetente e o destinatário troquem uma chave de criptografia simétrica de forma segura usando criptografia de chave pública:

1. Alice obtém uma cópia da chave pública RSA ou ECC do Roberto, normalmente por meio do certificado digital do Roberto.
2. Alice criptografa a mensagem usando uma cifra de chave secreta, como AES. Nesse contexto, a chave secreta é denominada *chave de sessão*.
3. Alice criptografa a chave de sessão com a chave pública do Roberto.
4. Alice anexa a chave de sessão criptografada à mensagem de texto cifrado em um envelope digital e a envia ao Roberto.
5. Roberto usa sua chave privada para descriptografar a chave de sessão.
6. Roberto usa a chave de sessão para descriptografar a mensagem de texto criptografado.

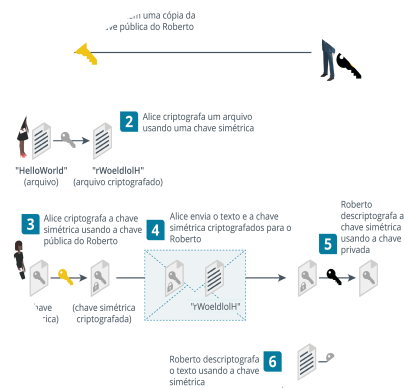


Figura 1. Troca de chaves usando um envelope digital.

Imagens © 123RF.com.

Descrição

As etapas envolvidas são as seguintes: 1. Alice obtém uma cópia da chave pública de Bob. 2. Alice criptografa um arquivo usando uma chave simétrica, convertendo “HelloWorld” (arquivo) em “rWoeldloIH” (arquivo criptografado). 3. Alice criptografa a chave simétrica usando a chave pública de Bob. 4. Alice envia o texto cifrado e a chave simétrica criptografada para Bob. 5. Bob descriptografa a chave simétrica com a chave privada. 6. Bob descriptografa o texto cifrado usando a chave simétrica, transformando “rWoeldloIH” em “HelloWorld”.

A criptografia de transporte também usa criptografia para garantir a integridade e autenticidade das mensagens, de forma a que o destinatário possa verificar se elas não foram modificadas por alguém que não seja o remetente. A verificação de integridade e autenticidade pode utilizar um [[código de autenticação de mensagem baseado em hash (HMAC)]]. Um código de autenticação de mensagem com base hash combina a chave secreta obtida durante a troca de chaves com um hash da mensagem.

Nota:

Opcionalmente, a cifra simétrica pode ser criada para executar a Authenticated Encryption (AE) (criptografia autenticada). Esse tipo de modo de operação de cifra simétrica garante confidencialidade e integridade/autenticidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

No sigilo encaminhado perfeito, ao usar um envelope digital, as partes devem trocar ou concordar numa chave secreta de criptografia em massa, usada com a cifra simétrica escolhida. Na implementação original de envelopes digitais, o servidor e o cliente trocam chaves secretas, e usam o par de chaves do servidor para proteger a troca contra

espionagem (snooping). Neste modelo de troca de chaves, se os dados de uma sessão forem gravados e, posteriormente, a chave privada do servidor for comprometida, ela poderá ser usada para descriptografar a chave de sessão e recuperar os dados confidenciais da sessão.

Esse risco decorrente da troca básica de chaves é mitigado pelo uso do [[Perfect Forward Secrecy (PFS)]]. O PFS utiliza o acordo de chaves [[Diffie-Hellman (D-H)]] para criar chaves de sessão efêmeras sem usar a chave privada do servidor. Diffie-Hellman permite que Alice e Roberto obtenham o mesmo segredo compartilhado ao compartilhar alguns valores relacionados. No processo de acordo, eles compartilham alguns dos valores, mas mantêm os outros privados. Melissa não consegue descobrir o segredo com os valores que são trocados publicamente. A autenticidade dos valores enviados pelo servidor é comprovada por meio de uma assinatura digital.

Figura 1. Utilização de Diffie-Hellman para obter um valor secreto a fim de gerar uma chave de criptografia simétrica



compartilhada de forma segura por meio de um canal público.

Imagens © 123RF.com.

Descrição

As etapas envolvidas são as seguintes: 1. Alice e Bob concordam publicamente com os valores de p e g . p é igual a 23 e g é igual a 9. 2. Alice escolhe um número aleatório (a) e o mantém em segredo. a é igual a 5. 3. Bob escolhe um número aleatório (b) e o mantém em segredo. b é igual a 3. 4. Alice calcula o valor de A maiúsculo como g elevado a a , módulo p , e o envia para Bob. Bob agora sabe que A maiúsculo é igual a 8, p é 23, g é 9 e b é 3. 5. Bob calcula o valor de B maiúsculo como g elevado a b , módulo p , e o envia para Alice. Alice agora sabe que B maiúsculo é igual a 16, p é 23, g é 9 e a é 5. A maiúsculo é 8 (9 elevado a 5 módulo 23) e B maiúsculo é 16 (9 elevado a 3 módulo 23). 6. Alice calcula o valor de s como B maiúsculo elevado a a , módulo p . Valor secreto para a chave simétrica: s igual a 6 (16 elevado a 5 módulo 23). 7. Bob calcula o valor de s como A maiúsculo elevado a b , módulo p . Valor secreto para a chave simétrica: s igual a 6 (8 elevado a 3 módulo 23). 8. Alice e Bob chegaram ao mesmo valor secreto para ser usado na geração de uma chave simétrica. 9. Mallory pode conhecer p , g , A maiúsculo e B maiúsculo, mas não pode conhecer s sem saber a ou b .

A utilização de chaves de sessão efêmeras implica que qualquer comprometimento futuro do servidor não resultará em um ataque aos dados gravados. Além disso, mesmo que um invasor consiga obter a chave de uma sessão, as outras sessões permanecerão confidenciais. Isso aumenta enormemente a quantidade de criptoanálise que um invasor teria de executar para recuperar uma “conversa” inteira.

Nota:

A aplicação de PFS usando a aritmética modular apresentada no diagrama é denominada Diffie-Hellman Ephemeral (DHE) (Diffie-Hellman efêmera). A implementação mais comum de PFS atualmente é a Elliptic Curve DHE (ECDHE) (curva elíptica DHE).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os valores usados para uma chave privada ou chave secreta devem ser selecionados aleatoriamente. Se houver algo previsível sobre a maneira como o valor da chave foi obtido, ela terá menos entropia. Baixa entropia é uma preocupação especial sempre que um sistema criptográfico faz uso de dados gerados pelo usuário, como uma senha. Os usuários tendem a selecionar senhas de baixa entropia, porque são mais fáceis de lembrar. Esse tipo de dado é muito curto e muito ordenado para servir como uma boa “semente” para a geração de chaves. Salt e alongamento de chave ajudam a proteger segredos criptográficos obtidos de senhas contra a descoberta por meio de criptoanálise.

Salting

As funções hash criptográficas são usadas, com frequência, para armazenamento e transmissão de senhas. Um hash não pode ser descriptografado de forma a recuperar a senha em texto simples que o gerou. As funções hash são unidirecionais. No entanto, as senhas armazenadas como hashes são vulneráveis a ataques de força bruta e dicionário.

Um autor de ameaças pode gerar hashes para tentar encontrar uma correspondência com um hash capturado do tráfego de rede ou de um arquivo de senhas. Um ataque de força bruta simplesmente percorre todas as combinações possíveis de letras, números e símbolos. Um ataque de dicionário gera hashes de palavras e frases comuns.

Ambos os ataques podem ser retardados pela adição de um valor de salt ao criar o hash. Um hash com salt é calculado da seguinte forma:

```
(salt + password) * SHA = hash
```

Um valor de salt exclusivo e aleatório deve ser gerado para cada conta de usuário. Isso reduz o risco de que, se os usuários escolherem senhas de texto simples idênticas, haverá valores de hash idênticos no arquivo de senhas. O salt não é mantido em segredo, porque qualquer sistema que verifique o hash precisa saber o valor dele. Isso significa simplesmente que um invasor não pode usar tabelas pré-calculadas de hashes. Os valores de hash devem ser recompilados com o valor de salt específico para cada senha.

Key Stretch

[[Key stretching]] utiliza uma chave gerada a partir de uma senha do usuário combinada com um valor de salt aleatório e a converte repetidamente em uma chave maior e mais desordenada. A chave inicial pode ser submetida a milhares de rodadas de hash. Isso pode não ser difícil para o invasor replicar, então na verdade não torna a chave mais forte. No entanto, é eficaz para retardar o ataque, já que o invasor precisa fazer todo esse processamento adicional para cada valor de chave possível. Uma forma de realizar o alongamento de chave é por meio do uso de uma biblioteca de software específica para fazer o hash e salvar as senhas quando são criadas. A Password-Based Key Derivation Function 2 (PBKDF2) (função de derivação de chave baseada em senha 2) é amplamente utilizada para esse fim, especialmente como parte do acesso Wi-Fi protegido (WPA).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Blockchain]] é um conceito em que uma lista crescente de registros transacionais é protegida por meio de criptografia.

Cada registro é chamado de *bloco* e passa por uma função hash. O valor do hash do bloco anterior na cadeia é adicionado ao cálculo do hash do próximo bloco na cadeia. Isso garante que cada bloco sucessivo seja vinculado criptograficamente. Cada bloco valida o hash do bloco anterior até o início da cadeia, garantindo que cada transação histórica não seja adulterada. Além disso, cada bloco geralmente inclui uma marcação da data/hora de uma ou mais transações, bem como os dados envolvidos nas próprias transações.

O blockchain é registrado em um [[livro-razão público e aberto]]. Esse registro público aberto não existe como um arquivo individual em um único computador, pois uma das características mais importantes de uma blockchain é ser descentralizada. O registro é distribuído por uma rede peer-to-peer (P2P) para reduzir os riscos associados a um único ponto de falha ou comprometimento. Portanto, os usuários da blockchain podem confiar entre si na mesma medida. Da mesma forma, outra qualidade que define uma blockchain é sua abertura: todos têm a mesma capacidade de visualizar todas as transações em uma blockchain.

A tecnologia blockchain tem uma variedade de aplicações possíveis. Ela pode garantir a integridade e a transparência de transações financeiras, contratos legais, proteção de direitos autorais e de propriedade intelectual, sistemas de votação on-line, sistemas de gerenciamento de identidade e armazenamento de dados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Ofuscação]] é a prática de tornar uma mensagem ou dado difícil de ser encontrado. Trata-se de segurança por obscuridade, técnica de modo geral obsoleta. No entanto, existem algumas aplicações para as tecnologias de ofuscação:

- [[Esteganografia]] (literalmente, “escrita oculta”) incorpora informações dentro de uma fonte inesperada; uma mensagem oculta em uma imagem, por exemplo. O documento ou arquivo que contém as informações é chamado de *cover text*. A mensagem pode ser criptografada por algum mecanismo antes de ser incorporada, fornecendo confidencialidade. A tecnologia também pode fornecer integridade ou não repúdio; por exemplo, poderia mostrar que algo foi impresso em um dispositivo específico em um determinado momento, o que poderia confirmar ser genuíno ou falso, dependendo do contexto.
- [[Mascaramento de dados]] pode significar que todo ou parte do conteúdo de um campo de banco de dados é redigido por meio da substituição de todas as cadeias de caracteres por “x”, por exemplo. Um campo pode ser parcialmente editado para preservar metadados para fins de análise. Por exemplo, em um número de telefone, o prefixo de discagem pode ser mantido, mas o número do assinante é editado. O mascaramento de dados também pode usar técnicas para preservar o formato original do campo.
- [[Tokenização]] significa que todo ou parte do valor de um campo de banco de dados é substituído por um token gerado aleatoriamente. O token é armazenado com o valor original em um servidor de tokens ou cofre de tokens, separado do banco de dados de produção. Se necessário, uma consulta ou aplicativo autorizado consegue recuperar o valor original do cofre, portanto, a tokenização é reversível. A tokenização é usada como um substituto da criptografia já que, do ponto de vista regulatório, um campo criptografado tem o mesmo valor que os dados originais.

O mascaramento de dados e a tokenização são usados para desidentificação. A desidentificação ofusca os dados pessoais de bancos de dados para que sejam compartilhados sem comprometer a privacidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de resumir os tipos de funções criptográficas (algoritmo de hash, cifra simétrica, cifra assimétrica) e explicar como elas são usadas em assinaturas digitais, certificados digitais e produtos de criptografia de disco/arquivo/banco de dados/transporte para fornecer confidencialidade, integridade e autenticação. Você deve se familiarizar com as ferramentas e procedimentos usados para emitir diferentes tipos de certificados e gerenciar operações de PKI.

Diretrizes para implementar soluções criptográficas

Siga estas diretrizes ao implementar soluções criptográficas:

- Crie políticas para exigir o uso de cifras e comprimentos de chave fortes, como os seguintes:
 - Par de chaves assimétricas para assinatura: RSA de 2.048 bits ou ECC de 256 bits.
 - Par de chaves assimétricas para troca de chaves: RSA de 2.048 bits ou ECDHE de 256 bits.
 - Chave secreta: AES-128 ou AES-256.
 - Hashing: SHA256 ou SHA512 (com MD5 permitido para requisitos de compatibilidade documentados).
- Decida se deve usar uma autoridade de certificação privada ou certificados externos e tome medidas para garantir a segurança de qualquer autoridade de certificação root privada usada.
- Determine políticas e tipos de certificados que atendam às necessidades dos usuários e fluxos de trabalho de negócios, como servidor/máquina, e-mail/usuário e tipos de certificados de assinatura de código. Certifique-se de que os campos de atributos estejam configurados corretamente ao emitir certificados, tomando cuidado especial para garantir que o campo SAN liste domínios, subdomínios ou domínios curinga pelos quais um servidor é acessado.
- Crie políticas e procedimentos para que usuários e servidores enviem CSRs, além dos processos de identificação, autenticação e autorização para garantir que os certificados sejam emitidos apenas para sujeitos válidos.
- Estabeleça procedimentos para gerenciar chaves e certificados, incluindo revogação e backup/escrow de chaves, idealmente usando criptoprocessadores de hardware dedicados como TPMs e HSMs.



This content is only available on larger screen sizes. Please revisit this page on a larger device.